3.7.1 Authentication assurance levels

A common way to compare authentication strength is to use NIST's authentication assurance levels (AAL) from NIST SP 800-63B, the same document where we found the identity assurance levels given in table 3.1. Table 3.3 shows the NIST AALs.

Table 3.3 NIST's Authentication Assurance Levels (AAL) categorize the strength of authentication mechanisms based on their resistance to common attacks and their ability to establish trust. This table summarizes each level, ranging from basic single-factor authentication to hardware-backed, cryptographically secure methods that are suitable for high-risk environments.

AAL Level	Description	Example authentication process
AAL1 (low)	Requires single-factor authentication. No requirement for resistance to eavesdropping or replay attacks.	Password-only login to a news website or basic SaaS app.
AAL2 (moderate)	Requires multi-factor authentication. At least one factor must be resistant to replay attacks (for example, OTP, cryptographic token).	Password + OTP from an authenticator app or SMS.
AAL3 (high)	Requires hardware-based authenticator that is resistant to phishing, impersonation, and replay. Authentication must use proof of possession of a cryptographic key.	Smart card + PIN; or FIDO2 security key that signs a challenge during login.

The NIST classification is widely used in United States federal IT systems and regulated industries like healthcare and financial services. While HIPAA (a federal law regulating healthcare records) doesn't explicitly mandate AALs, many healthcare vendors reference it as a concise way to assess identity system-related risk. Similarly, financial institutions regularly use NIST AALs to align their practices with federal guidance on protecting customer data and preventing fraud. You'll often see AALs referenced in authentication system vendor literature to describe the strength of their authentication options. Globally, many governments and standards bodies use frameworks that are inspired by or align with NIST AALs.